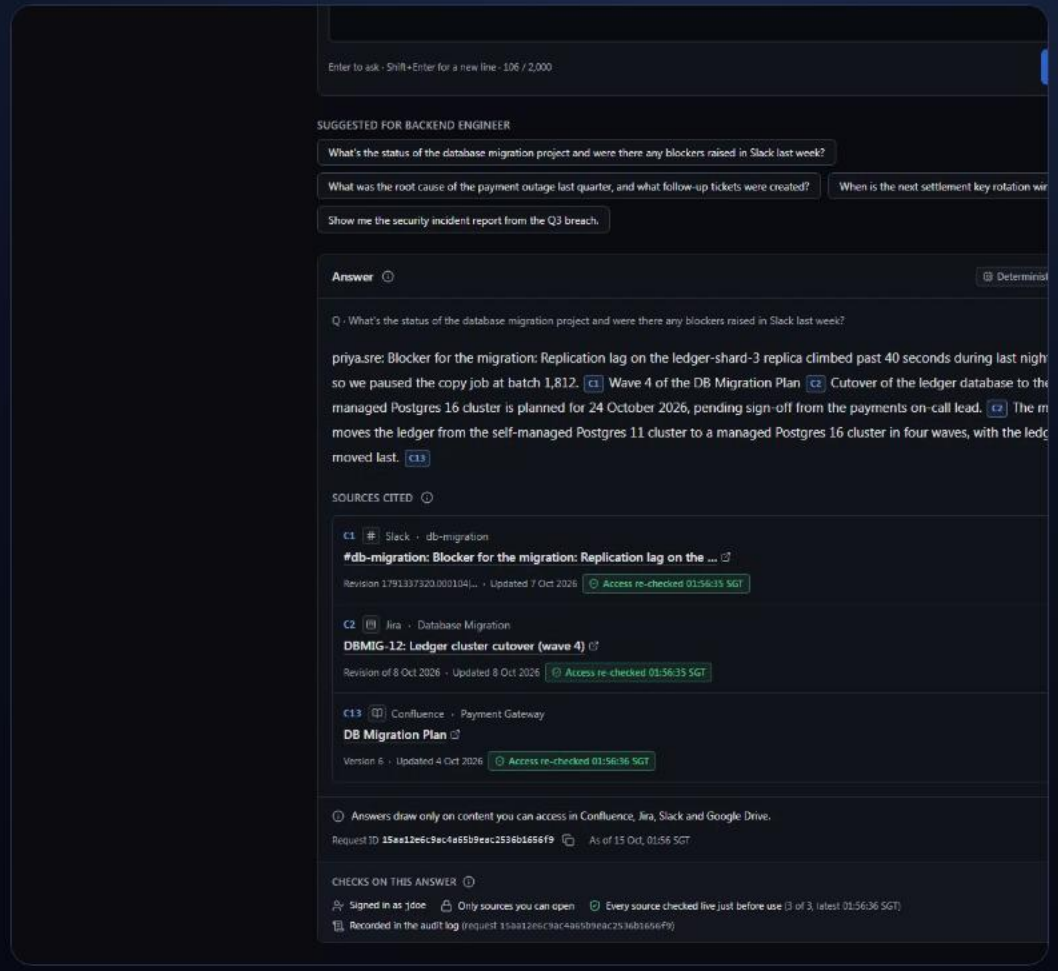
FINTECH TRACK · ASPIRE · "THE INTERNAL BRAIN"

Ask your whole company. See only what you're allowed to.

One assistant across Confluence, Jira, Slack and Google Drive. Every answer cited, every source permission-checked twice, every access written to an audit log that can't be quietly edited.

- Knowledge across 4 platforms
- Restrictions per person
- Tamper-evident audit
- Built with CodeBuddy · WorkBuddy



A real answer: one question, three platforms, every source re-checked.

THE PROBLEM

The answer exists. Finding it safely is the hard part.

~30%

of the work week goes to looking for information

ASPIRE · INTERNAL BRAIN CHALLENGE BRIEF

~3M

sensitive records per organisation accessed by Microsoft Copilot in H1 2025

CONCENTRIC AI · DATA RISK REPORT 2H 2025

9.3

CVSS of EchoLeak (CVE-2025-32711): a zero-click prompt injection that leaked Copilot data

REPORTED BY THE HACKER NEWS, JUNE 2025

In a fintech, one leak can be a crime

Telling a customer that a suspicious-transaction report exists is tipping-off (Singapore CDSA s.57, s.48 before the 2020 Revised Edition; MAS Notice PSN01). An assistant that can read everything can leak everything, so most regulated firms simply don't roll one out.

50,000+

businesses run their finances on Aspire

TECHNODE · APRIL 2026

10+

licences across SG, HK, AU, EU, US and CA: many regulators, many policies, many audiences

TECHNODE · APRIL 2026

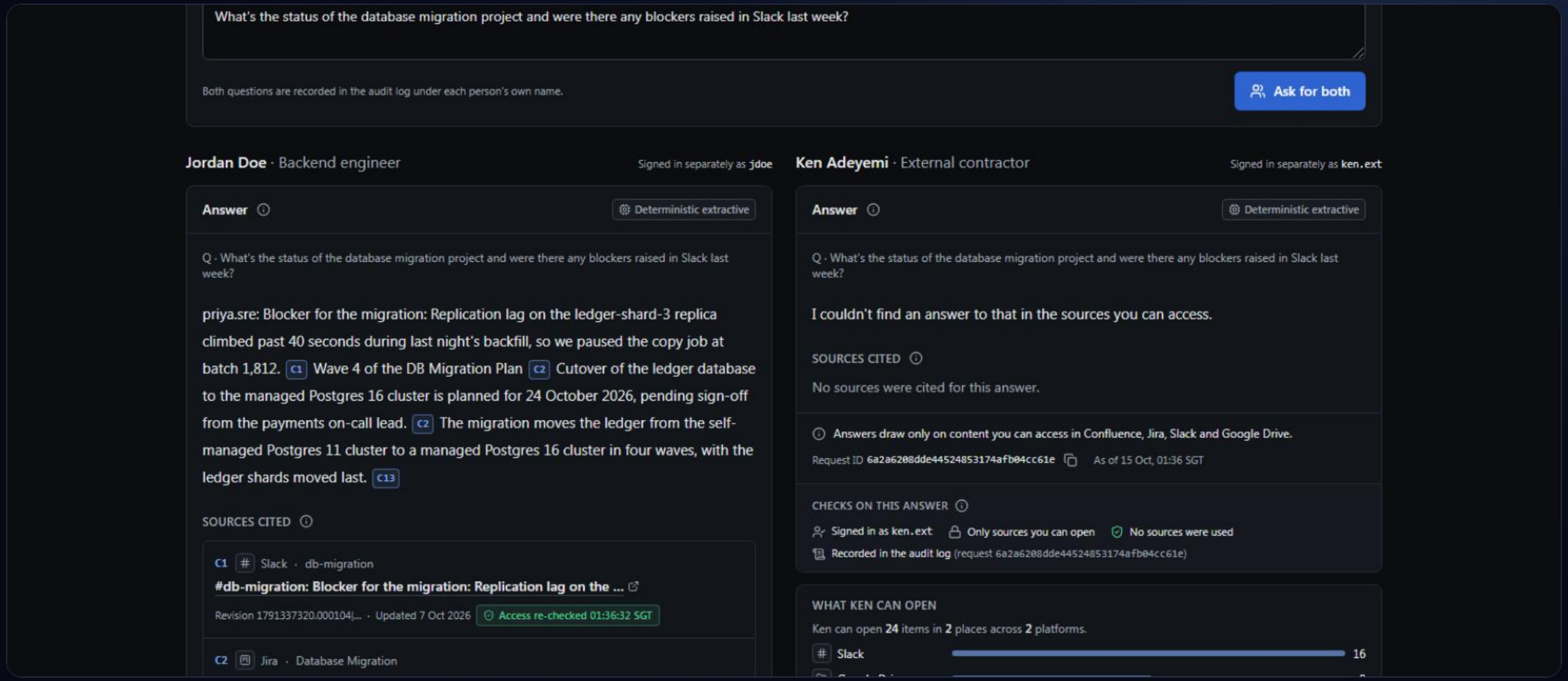
Oct 2026

MAS issued its Guidelines on AI Risk Management, covering payment institutions

MAS MEDIA RELEASE

THE IDEA, ON ONE SCREEN

Same question. Two people. Two honest answers.



Live app: Jordan (engineer) gets the cited answer. Ken (contractor) gets the standard refusal, with no hint that more exists.

HOW IT WORKS

Two checks before the model. One after. A record before anything is shown.

01
Who's asking
A signed token from the web app or WorkBuddy. Never a name typed into a box.

02
Gate 1
Search only what this person may open, using each platform's own permission model.

03
Gate 2
Ask the source again, live, for every passage. Error or timeout means no.

04
Answer
With a TokenHub key, Tencent Hy3 writes from those passages only; without one we quote them directly.

05
Grounding
Every sentence cites a passage; unsupported numbers and names are dropped.

Audit log: written before retrieval, before the model, before the answer is shown. Hash-chained and sealed. If it can't be written, nothing is answered.

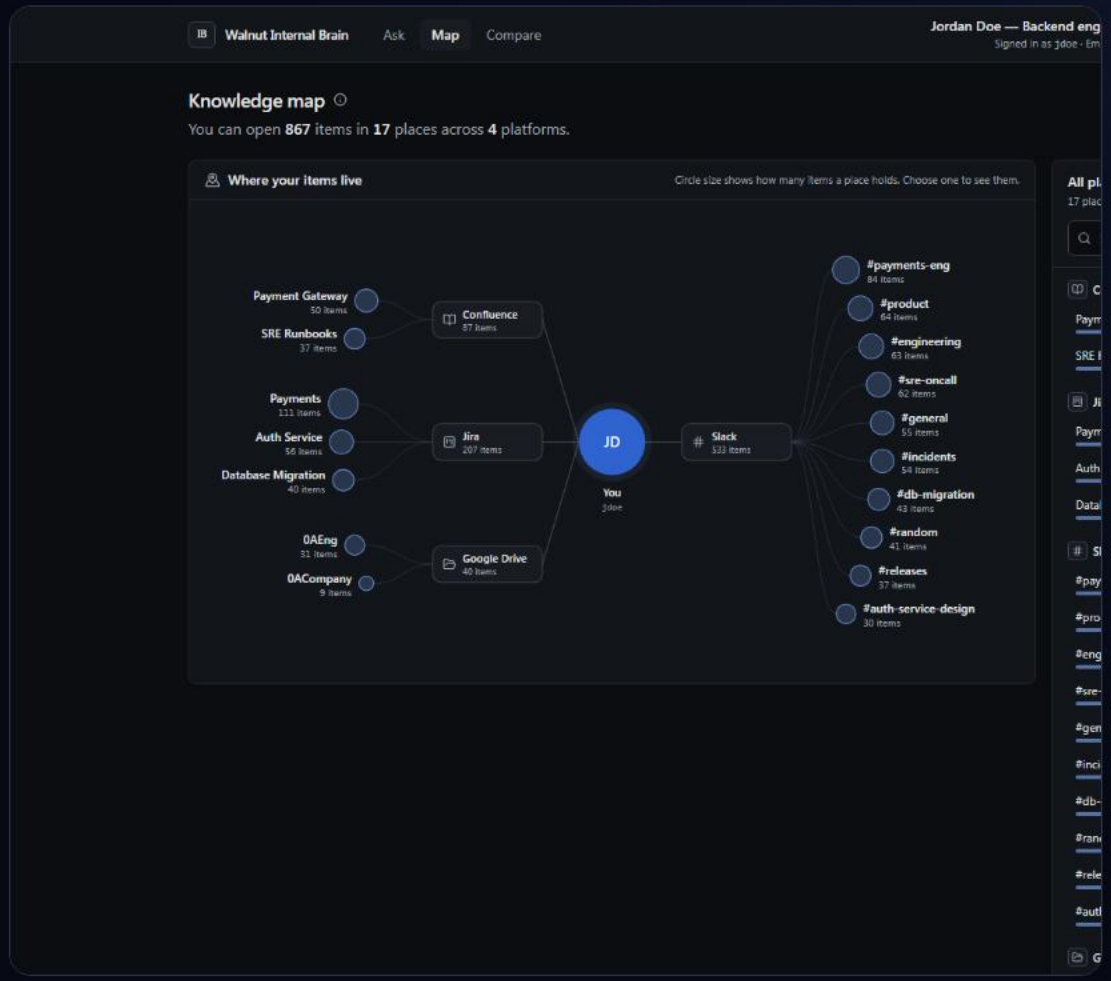
Restricted = doesn't exist
The same refusal, byte for byte, whether a document is restricted or was never written.

Revoked = gone next question
Remove someone from a channel and their very next answer no longer uses it, even if the notification is lost.

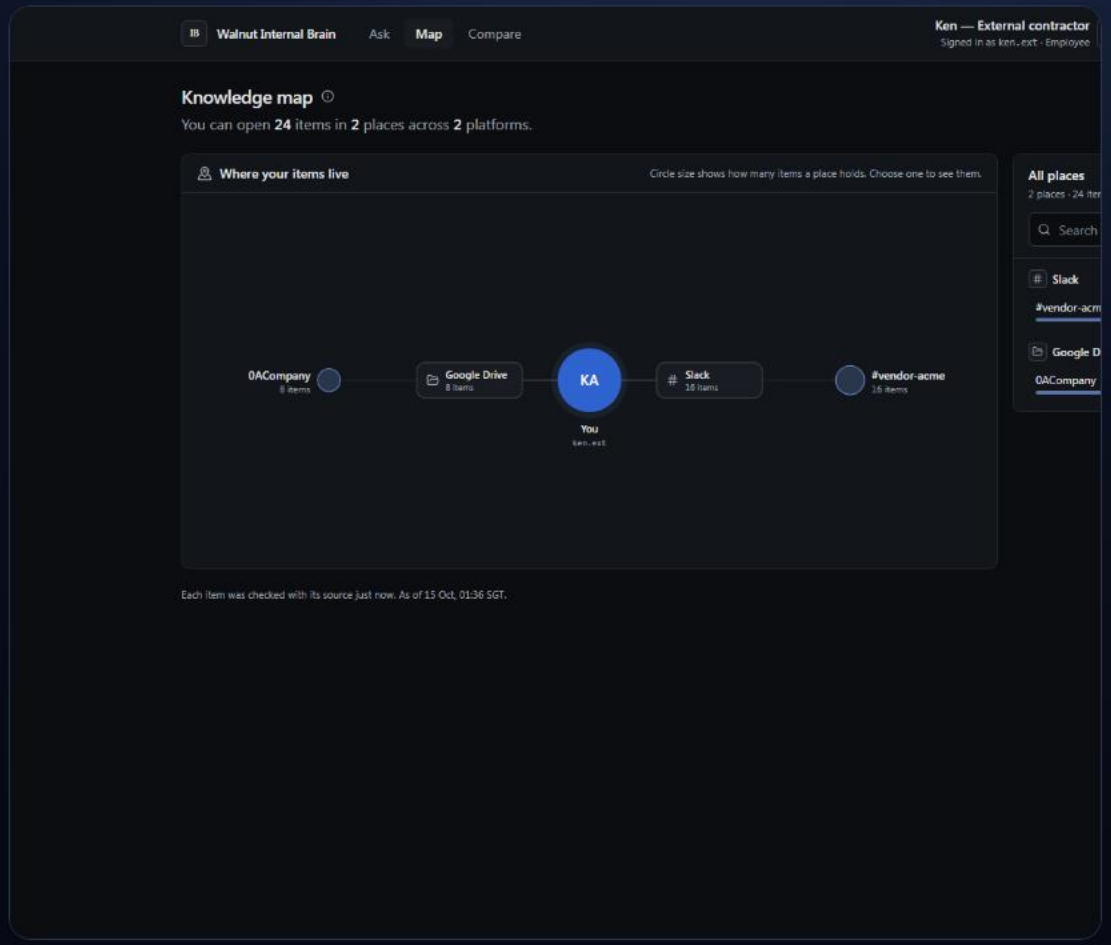
Changed = re-read first
An edited document is re-read and re-checked before use, and the citation shows the new version.

KNOWLEDGE, SHAPED BY PERMISSIONS

Everything you can open. Nothing you can't.



Jordan, engineer: 867 items in 17 places on 4 platforms.



Ken, contractor: 24 items in 2 places. No "+843 hidden". Each item checked live with its source.

BUILT FOR A FINTECH

Four things a payments company needs on day one

FinCrime compartment

Suspicious-transaction case notes are readable only by the MLRO. An account manager asking about that customer gets the approved script, word for word the same as for a company that doesn't exist.

Answers per market

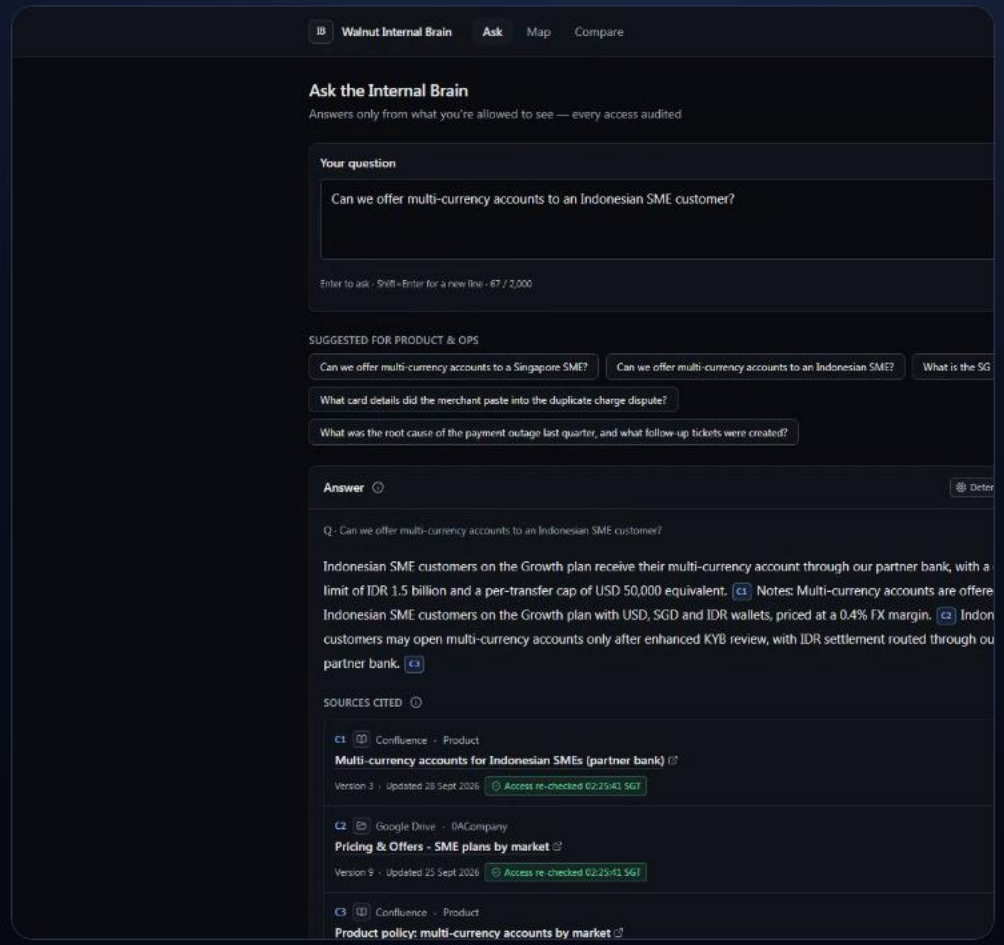
"What can we offer this SME?" gets a different, correct answer for Singapore and Indonesia, each citing that market's approved policy.

Approved policies only

A draft fee schedule with different numbers is never cited. Only the approved version counts.

Card and ID masking

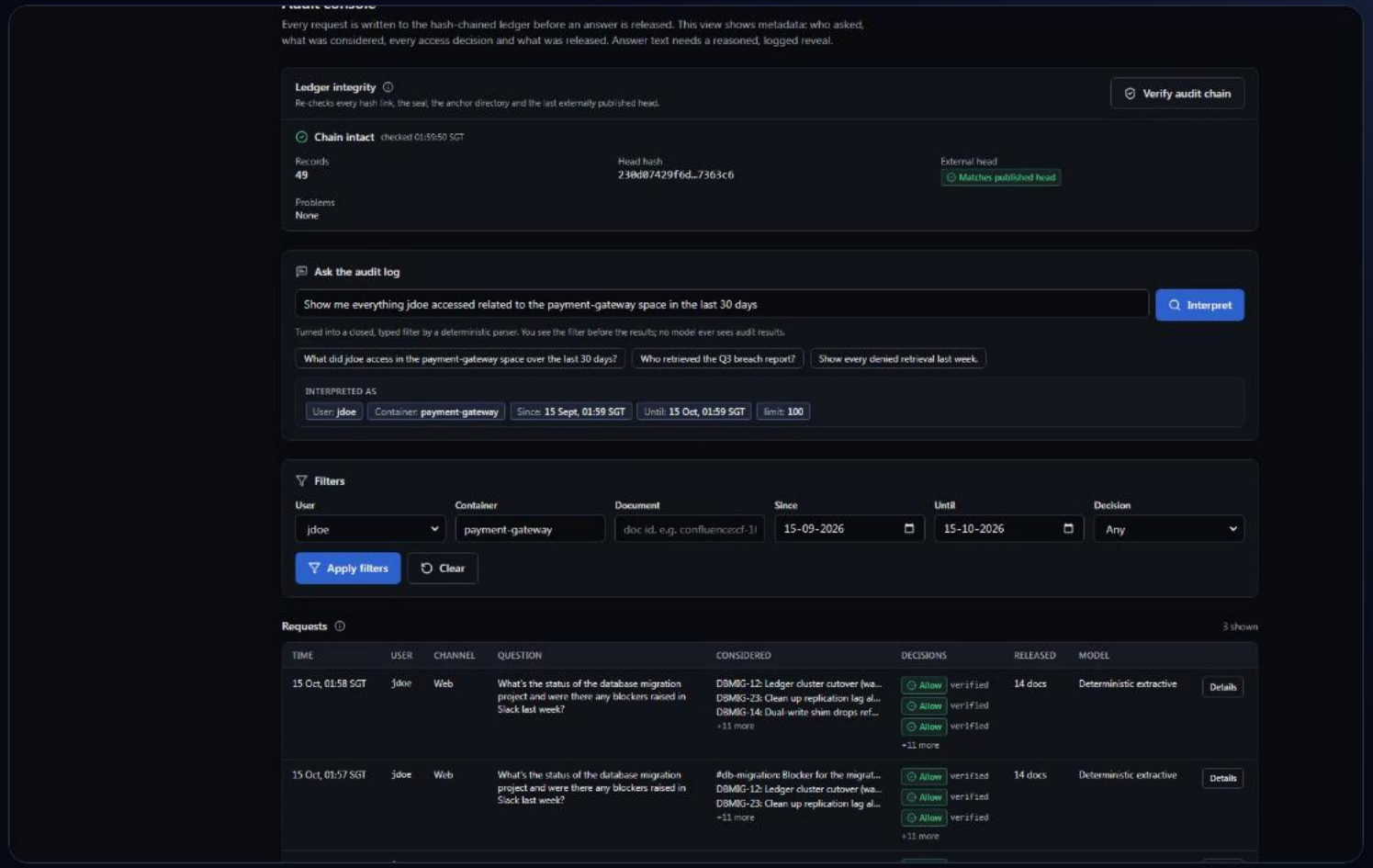
Card numbers, CVVs, IBANs and NRICs are masked before indexing, so they never reach the index or a model.



Ops asks about an Indonesian SME: the answer cites only the Indonesia policy and pricing.

THE AUDIT TRAIL

Who asked what, what was allowed, and proof nobody edited it



Compliance asks in plain English; it becomes a visible filter. Every allow/deny decision per document. "Verify audit chain" re-checks every record and every stored answer.

7 / 7

tamper attacks detected: edits, deletions, rollback, a key-holder rewrite. The 8th case, a rollback after the last off-host head, is our stated limit

SCRIPTS/TAMPER_DEMO.PY · REAL OUTPUT

Reasoned reveal

Compliance sees metadata by default. Reading an answer needs a reason, and the reveal is logged too.

MEASURED, NOT PROMISED

We attacked it on purpose

0

leaks of restricted content in 5,958 adversarial requests

EVALS/INTERNAL_BRAIN/RESULTS.MD

0 / 400

differences between "restricted" and "doesn't exist"

P2 DIFFERENTIAL TEST

0

prompt-injection failures, with planted instructions on all four platforms

INJECTION PROBES

632

automated tests on the Internal Brain

7

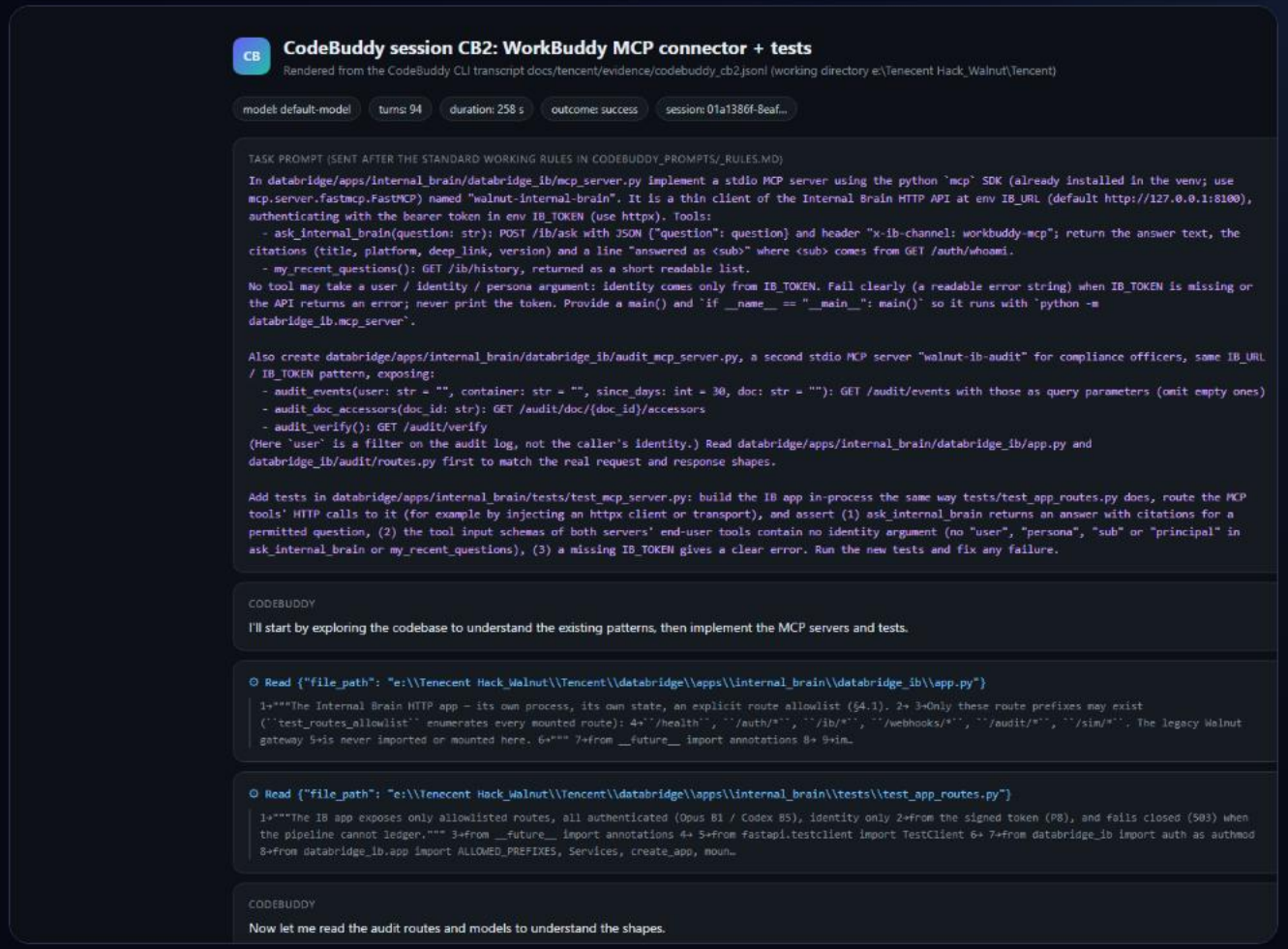
independent security reviews (6 Codex passes, CodeBuddy on Hy3), every finding fixed or documented

100%

recall on questions people are allowed to answer

BUILT WITH TENCENT

CodeBuddy built it. WorkBuddy is the second front door.



CodeBuddy session CB2: WorkBuddy MCP connector + tests

Rendered from the CodeBuddy CLI transcript docs/tencent/evidence/codebuddy_cb2.jsonl (working directory e:\Tenecent Hack_Walnut\Tencent)

model: default-model | turns: 94 | duration: 258 s | outcome: success | session: 01a1386f-8eaf...

TASK PROMPT (SENT AFTER THE STANDARD WORKING RULES IN CODEBUDDY_PROMPTS/_RULES.MD)

In databridge/apps/internal_brain/databridge_ib/mcp_server.py implement a stdio MCP server using the python `mcp` SDK (already installed in the venv; use mcp.server.fastmcp.FastMCP) named "walnut-internal-brain". It is a thin client of the Internal Brain HTTP API at env IB_URL (default http://127.0.0.1:8100), authenticating with the bearer token in env IB_TOKEN (use httpx). Tools:
- ask_internal_brain(question: str): POST /ib/ask with JSON {"question": question} and header "x-ib-channel: workbuddy-mcp"; return the answer text, the citations (title, platform, deep_link, version) and a line "answered as <sub>" where <sub> comes from GET /auth/whoami.
- my_recent_questions(): GET /ib/history, returned as a short readable list.
No tool may take a user / identity / persona argument: identity comes only from IB_TOKEN. Fail clearly (a readable error string) when IB_TOKEN is missing or the API returns an error; never print the token. Provide a main() and `if __name__ == "__main__": main()` so it runs with `python -m databridge_ib.mcp_server`.

Also create databridge/apps/internal_brain/databridge_ib/audit_mcp_server.py, a second stdio MCP server "walnut-ib-audit" for compliance officers, same IB_URL / IB_TOKEN pattern, exposing:
- audit_events(user: str = "", container: str = "", since_days: int = 30, doc: str = ""): GET /audit/events with those as query parameters (omit empty ones)
- audit_doc_accessors(doc_id: str): GET /audit/doc/{doc_id}/accessors
- audit_verify(): GET /audit/verify
(Here `user` is a filter on the audit log, not the caller's identity.) Read databridge/apps/internal_brain/databridge_ib/app.py and databridge_ib/audit/routes.py first to match the real request and response shapes.

Add tests in databridge/apps/internal_brain/tests/test_mcp_server.py: build the IB app in-process the same way tests/test_app_routes.py does, route the MCP tools' HTTP calls to it (for example by injecting an httpx client or transport), and assert (1) ask_internal_brain returns an answer with citations for a permitted question, (2) the tool input schemas of both servers' end-user tools contain no identity argument (no "user", "persona", "sub" or "principal" in ask_internal_brain or my_recent_questions), (3) a missing IB_TOKEN gives a clear error. Run the new tests and fix any failure.

CODEBUDDY

I'll start by exploring the codebase to understand the existing patterns, then implement the MCP servers and tests.

Read {"file_path": "e:\\Tenecent Hack_Walnut\\Tencent\\databridge\\apps\\internal_brain\\databridge_ib\\app.py"}

1→"""The Internal Brain HTTP app — its own process, its own state, an explicit route allowlist (§4.1). 2→ 3→Only these route prefixes may exist (``test_routes_allowlist`` enumerates every mounted route): 4→ ``/health``, ``/auth/*``, ``/ib/*``, ``/webhooks/*``, ``/audit/*``, ``/sim/*``. The legacy Walnut gateway 5→is never imported or mounted here. 6→""" 7→from __future__ import annotations 8→ 9→im…

Read {"file_path": "e:\\Tenecent Hack_Walnut\\Tencent\\databridge\\apps\\internal_brain\\tests\\test_app_routes.py"}

1→"""The IB app exposes only allowlisted routes, all authenticated (Opus B1 / Codex B5), identity only 2→from the signed token (P8), and fails closed (503) when the pipeline cannot ledger.""" 3→from __future__ import annotations 4→ 5→from fastapi.testclient import TestClient 6→ 7→from databridge_ib import auth as authmod 8→from databridge_ib.app import ALLOWED_PREFIXES, Services, create_app, moun…

CODEBUDDY

Now let me read the audit routes and models to understand the shapes.

CodeBuddy session CB2 building the WorkBuddy MCP connector (every session's transcript is in the repository).

CodeBuddy · 6 sessions

Trust-boundary diagram, WorkBuddy connector, token tool, model-chain tests, a security review on Hy3, then hardening its own code.

WorkBuddy · 3 workspaces

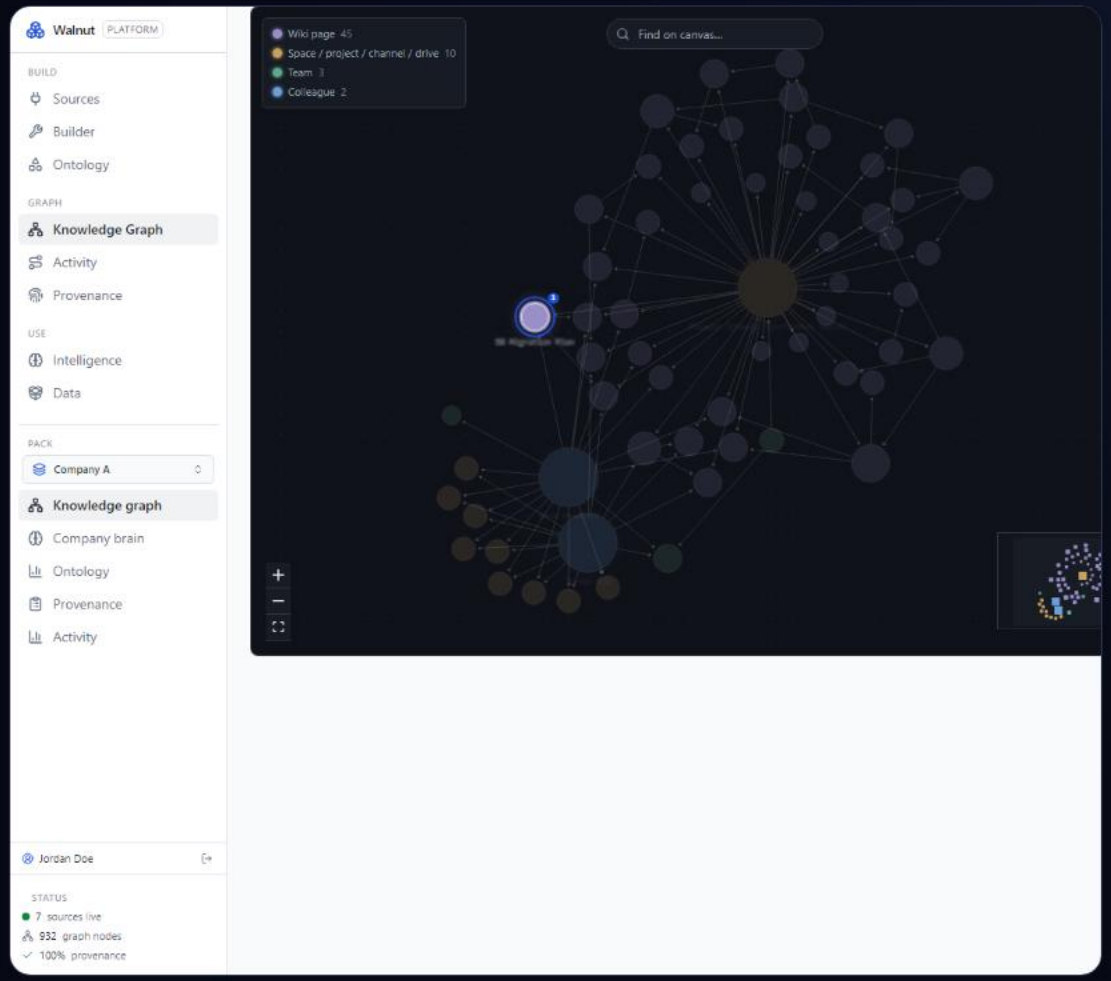
Ask as an engineer or a contractor, or audit as compliance. Each carries its own signed token.

TokenHub · Hy3 · Lighthouse · Miora

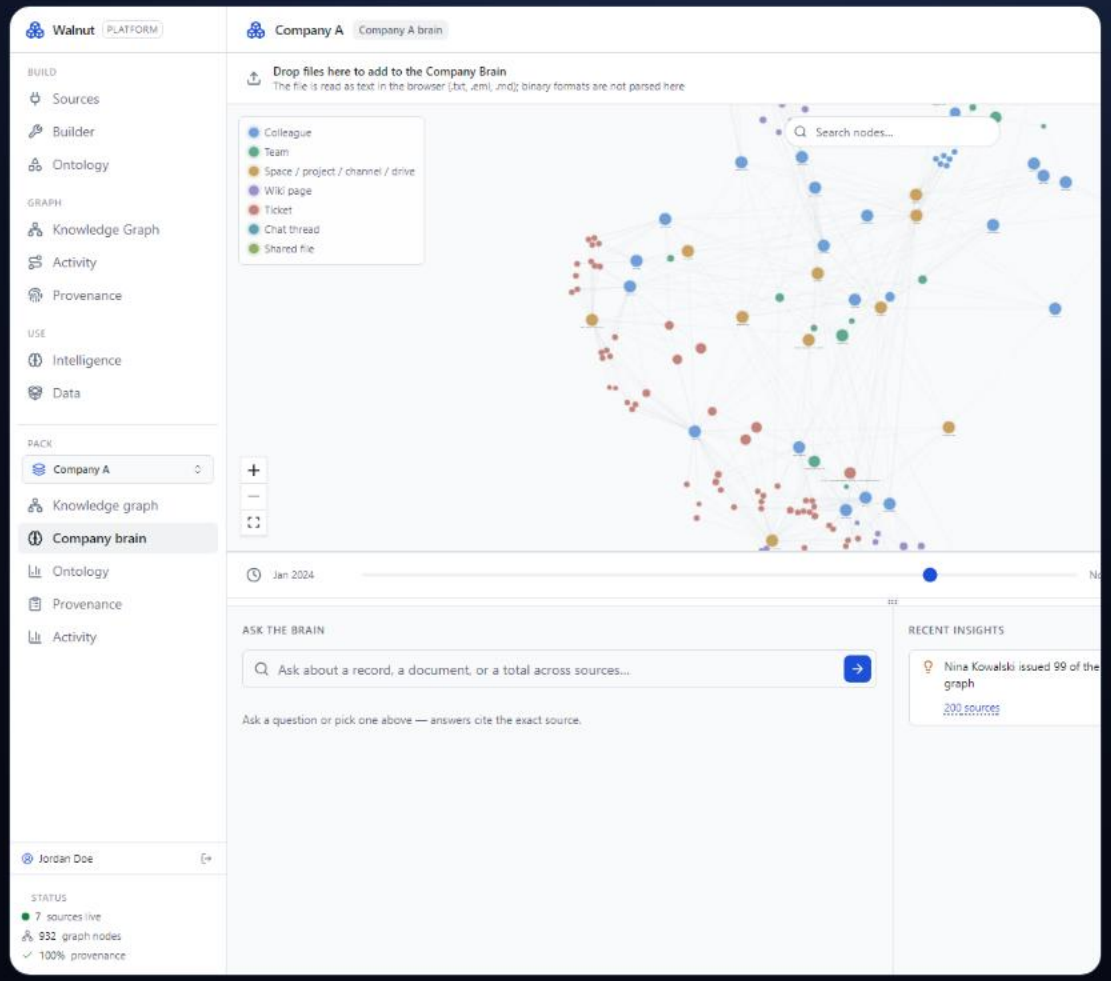
Hy3 with DeepSeek fallback (configured; the Hy3 run is pending); a hardened Lighthouse deploy kit; the cover made in Miora.

WHAT'S UNDERNEATH

The Walnut evidence engine, reused as it was



Knowledge graph: every attribute points to the record it came from.



Company brain with a time slider: what the company knew on any date.

FOR ASPIRE

From demo to pilot in four weeks

WEEK 1

Connect

Point the four connectors at Aspire's real Confluence, Jira, Slack and Drive (a base-URL change; same code path as the demo).

WEEK 2

Identity

Replace demo sign-in with Aspire's SSO; keep the ledger key in a managed key store.

WEEK 3

Prove it

Run the leak evaluation on Aspire's own permissions; compliance reviews the audit console.

WEEK 4

Pilot

One team (e.g. payments engineering), in the web app and WorkBuddy, with the audit log reviewed weekly.

Ahead of the MAS Guidelines on AI Risk Management (issued Oct 2026): model, prompt version and evidence are already logged for every answer, with human oversight through the audit console.

HONEST LIMITS, AND WHAT'S NEXT

What we don't claim yet

- The four platforms are mocked with their real API shapes and permission rules; the connectors haven't run against a real tenant yet.
- Sign-in is a demo login standing in for SSO; a deployed build refuses to start without a passcode.
- The grounding check verifies numbers and names, not the relations between them.
- Someone holding the ledger's sealing key could rewrite records after the last off-host published head; we say so and test it.
- All numbers come from a test model and the deterministic path; the Hy3 run waits on Tencent account verification.

Next

Real-tenant connector runs · SSO · ledger key in a managed key store · Hy3 evaluation · relation checks in the grounding wall

Why say this?

A compliance tool that overclaims is worse than none. Every claim on these slides links to a test or a file.

THANK YOU

Walnut Internal Brain

The repository's INTERNAL_BRAIN.md shows what to look at first, how to run it in two commands, and the evidence behind every claim on these slides.

github.com/IshaanSirbhaiya/Tencent | Start at INTERNAL_BRAIN.md | 7-minute demo video